KIT DO DESENVOLVEDOR · HANDOFF TÉCNICO OFICIAL · V2 · SETEMBRO 2026

VERIMULTA

Handoff de Desenvolvimento

Este documento + o repositório = tudo o que uma equipe precisa para assumir, endurecer e escalar a plataforma sem uma única reunião de descoberta. O sistema **já funciona e é testado de ponta a ponta** — a missão aqui descrita é publicar nas lojas, ligar as integrações oficiais e fechar o que sobrou de operação.

Mapa do código (6_CODIGO_FONTE/sistema)

ARQUIVO	RESPONSABILIDADE	STATUS
`servidor.js`	API REST /v1 (Express): auth JWT, veículos, multas, scan, diagnóstico, defesas, PDF, assinaturas, webhook, admin e direitos do titular.	testado e2e
`planos.js`	**Fonte única** da grade. Servidor e checkout leem daqui; `ALIASES` mantém as chaves antigas válidas.	testado
`motor_auditoria.js`	As 14 verificações A1–A14 (CTB 280–282, CONTRAN 900/918/2022, INMETRO 158/2022) + jurimetria v2 com correlação e teto.	caso real: 30%
`config.js`	Segredos obrigatórios em produção (aborta no boot sem eles) + comparação `timingSafeEqual`.	testado
`seguranca.js`	Rate limit por IP (janela deslizante), CORS por allowlist e cabeçalhos de endurecimento.	testado
`pagamentos.js`	Mercado Pago: preapproval, webhook com HMAC + reconsulta de status, cancelamento em 1 toque.	ciclo validado
`pdf.js`	Defesa Prévia e Extrato de Auditoria em PDF timbrado (pdfkit, sem dependência nativa).	testado
`ocr.js`	Google Vision (quando há chave) + extrator de campos + tabela de pontuação do CTB.	testado
`emails.js`	SMTP transacional: boas-vindas, pagamento confirmado, alertas de prazo 7/3/1 com dedup.	testado
`monitor.js`	Varredura diária de prazos + fontes plugáveis (aguarda credenciamento — **nunca scraping**).	prazos ativos
`banco.js`	SQLite (better-sqlite3) com migrations idempotentes embutidas.	testado
`publico/`	`app.html` (PWA), `index.html` (site), `admin.html` (painel), termos e privacidade.	testado
`teste.js` / `teste_api.js`	**56 asserções**: unitárias + integração HTTP do funil inteiro.	0 falhas

Stack: Node 22–24 · Express · better-sqlite3 · JWT · pdfkit · PWA sem framework (zero dependência frágil).

PARTE 2 · REFERÊNCIA DA API V1

Endpoints principais

ROTA	FUNÇÃO
`POST /v1/auth/register` · `/login`	Cadastro (**exige** `consentimento: true` e grava data, IP e versão do termo) e login » JWT. Rate limit por IP.
`GET/POST /v1/veiculos`	Listar e adicionar placas (limites por plano).
`POST /v1/multas/scan`	multipart foto » OCR » extração » grava a multa. Confere se o `veiculo_id` é do próprio usuário.
`GET /v1/multas/:id/diagnostico`	Motor: 14 verificações + **Índice de Consistência** + probabilidade (com gating por plano).
`POST /v1/recursos`	Gera a Defesa Prévia (402 sem assinatura — paywall no servidor).
`GET /v1/recursos/:id/pdf`	**Defesa Prévia em PDF timbrado**, gerada no servidor.
`GET /v1/multas/:id/extrato.pdf`	**Extrato de Auditoria em PDF**: as 14 verificações com a base legal de cada uma.
`POST /v1/checkout`	Demo ativa direto · Produção (`GATEWAY=mercadopago`) cria o preapproval e devolve o checkout.
`POST /v1/webhooks/mercadopago`	**O endereço a cadastrar no MP.** Valida HMAC » reconsulta o MP » libera/derruba o plano » e-mail » trilha. `/v1/webhooks/pagamento` responde igual (histórico).
`POST /v1/assinaturas/ativar`	Só fora de produção. Com `NODE_ENV=production` devolve **403** qualquer que seja o gateway.
`GET /v1/eu/dados` · `DELETE /v1/eu/conta`	LGPD art. 18: exportação completa e eliminação com anonimização.
`GET /v1/admin/*` (`X-Admin-Secret`)	Painel do Dono: usuários, assinaturas, MRR, trilha de pagamentos.
`GET /v1/saude`	Health check usado pelo Render.

Padrão: JSON, erros em `{erro}`, status HTTP corretos. Autenticação Bearer JWT · Admin por `X-Admin-Secret`. Contrato completo legível no `servidor.js`, comentado em português.

Tabelas e as chaves de ambiente

Tabelas (banco.js)

`usuarios` · `veiculos` · `multas` · `diagnosticos` · `recursos` · `assinaturas` · `pagamentos` · `emails_log` · `varreduras`.

PKs inteiras, FKs indexadas, timestamps, migrations idempotentes. **`usuarios` guarda o consentimento**: flag, data, IP e versão do termo. Migração recomendada para Postgres no Gate 5.

Environment

`NODE_ENV` · `DB_PATH` · `JWT_SECRET` · `ADMIN_SECRET` · `WEBHOOK_SECRET` · `GATEWAY` · `MP_ACCESS_TOKEN` · `URL_BASE` · `SMTP_HOST/PORT/USER/PASS` · `EMAIL_FROM` · `GOOGLE_VISION_KEY` · `ORIGENS_PERMITIDAS` · `FONTES_MONITORAMENTO` · `VERSAO_TERMOS`.

`DB_PATH` **tem de apontar para o disco persistente** (`/var/data`). `DEMO_NOVA_MULTA` jamais em produção.

O motor (coração intocável)

A1–A14 com base legal citada item a item; cada regra determinística e versionável. **Jurimetria v2:** teses do mesmo equipamento (A4–A8) e da mesma cadeia de notificação (A3, A13, A14) são famílias correlacionadas — a mais forte conta inteira, as demais com decaimento de 0,30 — e o resultado tem **teto de 85%**. Toda mudança de regra = teste novo + registro da versão que produziu o resultado.

PWA

`manifest.json` + `sw.js` prontos (instalável no Android/iOS pelo navegador). Ícones 192/512 na pasta. Caminho para a loja: PWABuilder » TWA (Google Play, US$ 25). Push notifications = Pacote B.

Blindar: o que já foi feito e o que falta

ENTREGA	SITUAÇÃO
Suíte de testes (unitário do motor + integração da API + e2e do funil pagar»liberar)	**Feito** — 56 asserções. Falta CI verde obrigatório em PR.
Hardening: rate limit, validação de upload, CORS por allowlist, cabeçalhos	**Feito.** Falta revisão formal do OWASP Top 10 documentada.
Consentimento LGPD gravado + direitos do titular (exportação e eliminação)	**Feito.**
Estimativa sem promessa de resultado (teto e correlação na jurimetria)	**Feito.**
MFA no Painel do Dono + logs imutáveis de operações sensíveis	Pendente — login admin exige 2º fator; trilha exportável.
Backup automático do banco + restore testado + plano de incidente	Pendente — restore executado com sucesso em staging.
Observabilidade: Sentry + logs estruturados + alerta de webhook falho com reprocesso	Pendente — falha simulada de webhook tem de se recuperar sozinha.
Teste de carga (k6/artillery): 200 usuários no funil scan»diagnóstico	Pendente — p95 < 2s no diagnóstico, zero erro 5xx.
Acessibilidade e revisão de copy com a matriz de evidência	Pendente — Índice de Consistência como manchete, escudo em toda estimativa.

Ambientes: dev » staging » prod · migrations por PR · zero dado sensível em log.

PARTE 4 · PACOTES B E C

Publicar nas lojas e escalar as integrações

Pacote B · Google Play (prioridade)

PWA » TWA via PWABuilder ou Bubblewrap · assets da loja prontos no KIT-LOJAS · conta developer US$ 25 · política de privacidade já no ar. **Aceite:** app publicado, instalável, atualização automática via PWA.

Pacote B · Push e polimento

Web Push (VAPID) no `sw.js` para nova multa, prazo 7/3/1 e pagamento confirmado, com **opt-in LGPD explícito**. Lighthouse >= 90 em performance/PWA/SEO · deep links · modo offline básico. iOS só após PMF (US$ 99/ano).

Pacote C · Data Gateway Serpro/Senatran

Camada desacoplada (adapter por fonte) consumindo as consultas contratadas via Credencia, com cache, retry e medição de custo por consulta. **Aceite:** fonte liga por config, custo por usuário visível no admin, **nunca scraping**.

Pacote C · Parceiros, rede e KPIs

Botão "pagar com parceiro" após diagnóstico válido, com tracking de comissão · rede de prestadores com verificação de credencial · dívida ativa por UF · KPIs v2 no painel (ativação, free»paid, churn D30/90, CAC, custo de consulta).

Ordem dos pacotes: A » B » C · nenhum item do C sem papel assinado da fonte de dados.

O que é inegociável

Criptografia e segredos

TLS em trânsito · senhas bcrypt · **nenhum segredo no código**, só variável de ambiente, com o processo abortando em produção se faltar. Dados sensíveis cifrados em repouso quando migrar para Postgres.

LGPD por design

Consentimento **inequívoco e gravado** no cadastro (art. 8º §2º) · minimização · direitos do titular como endpoints (`/v1/eu/dados`, `/v1/eu/conta`) · retenção do histórico de pagamento por obrigação fiscal, sem vínculo com pessoa identificável · RIPD quando ligar dado oficial.

Acesso

Menor privilégio · MFA no admin (pendente) · trilha de auditoria imutável de consultas e alterações · logs **sem** dados pessoais.

Linhas vermelhas

Nunca prometer cancelamento · **nunca** inventar multa (`DEMO_NOVA_MULTA` proibido em produção) · **nunca** scraping de portal governamental · estimativa sempre com escudo e **sempre abaixo de 100%**.

Como esta equipe entrega

Fluxo

Repositório privado · branch por tarefa · PR revisado obrigatório · CI com `npm test` + lint · deploy de staging automático, produção por aprovação · migrations versionadas no PR.

Definition of Done

`npm test` verde · estados vazio/carregando/erro em toda tela · sem dado sensível em log · escudo presente onde há estimativa · **README e os manuais atualizados no mesmo PR** · aprovado em staging.

A regra que este projeto aprendeu

Os manuais viveram fora do repositório e envelheceram em silêncio: chegaram a mandar cadastrar um webhook que respondia 404 e a vender um plano que o checkout recusava. **Agora os manuais são gerados por código** (`ferramentas/`), no mesmo commit da mudança.

Cadência

Sprints semanais com demo gravada · board único · relatório de sexta (feito, bloqueios, próximos) · acesso do dono ao painel de KPIs sempre. O dev não decide estratégia — executa esta pauta.

PARTE 7 · RESUMO EXECUTIVO PARA A PROPOSTA

O pedido em uma página (copie no e-mail)

"Temos uma plataforma SaaS **funcionando e testada de ponta a ponta** (Node/Express + PWA + Mercado Pago + OCR Vision), com deploy de 1 clique no Render, suíte de 56 asserções e documentação gerada por código. Contratamos: **PACOTE A** — o que falta de blindagem: MFA no admin, backup com restore testado, observabilidade com reprocesso de webhook, teste de carga e CI obrigatório (1–2 semanas); **PACOTE B** — publicação na Google Play via TWA + Web Push (2 semanas); **PACOTE C** — integrações sob demanda (Data Gateway Serpro, pagamento-parceiro, rede credenciada), por frente contratada. Exigimos: contrato com cessão de PI + NDA, PRs revisados, CI verde, staging antes de produção, e respeito absoluto às linhas vermelhas do produto (sem promessa de resultado, sem simulação de dados em produção, sem scraping). Envie proposta **por pacote**, com prazo, equipe e valor."

Critério de seleção: (1) já publicou app com pagamento recorrente · (2) mostra testes em projetos anteriores · (3) aceita cessão de PI sem drama · (4) fala simples. Quem falhar em 2 dos 4, não passa. Kit de envio: este PDF + acesso leitor ao repositório.

A RÉGUA

Bilionário não nasce do código — nasce da disciplina em cima dele.

Produto no ar · gates cumpridos · dados próprios.

Este kit garante que qualquer equipe pegue o Verimulta e o leve adiante do jeito certo — com a PrimeCorp dona de cada linha.
Verifica, Brasil.